



EMPOWERING THE
RESPONSIBLE USE OF AI



TABLE OF CONTENTS

1. OVERVIEW.....	2
1.1 INTRODUCTION	3
1.2 OBJECTIVE.....	3
1.3 SCOPE	3
1.4 RELATED POLICY AND PROCEDURES.....	3
2. AI REVIEW COMMITTEE (AIRC).....	3
2.1 AIRC AND TECHNICAL REVIEW BOARD (TRB) PROCESS MAP	4
2.2 AIRC LINKS	4
3. AI USE CASE RISK MATRIX.....	5
3.1 DECISION TABLE FOR AI INSTITUTIONAL RISK REVIEW	5
3.2 QUESTIONS FOR UNIT DIRECTOR CONSIDERATION	6
3.3 SAMPLE USE CASE CATEGORIZATION GUIDE	7
4. TEST AND EVALUATION GUIDELINES.....	8
4.1 TIERED TESTING FRAMEWORK.....	9
4.2 TIER 1 - AI WITH LIMITED CUSTOMIZATION: EXPEDITED PROTOCOL.....	9
4.3 TIER 2 - LARGE-SCALE USE WITH SMITHSONIAN DATA: ENHANCED PROTOCOL	10
4.4 TIER 3 - BESPOKE AI MODELS: COMPREHENSIVE PROTOCOL	12
4.5 CONCLUSION	14
5. APPROVED AI TOOLS AND MODELS.....	14
6. MODEL CATALOGING GUIDELINES	15
6.1 AI MODEL DOCUMENTATION COMPONENTS	15
7. AI SECURITY REQUIREMENTS.....	16
7.1 GENAI.....	17
7.2 GENAI-CREATED CODE.....	17
7.3 SYSTEM OWNER AND MANAGER RESPONSIBILITIES.....	18
7.4 DATA.....	18
7.5 AI MODEL PROTECTION	19
7.6 UNIQUE AI VULNERABILITIES.....	20
7.7 AI MODEL DEVELOPMENT	20

1. OVERVIEW

1.1 Introduction

At the Smithsonian Institution (SI), we recognize the transformative potential of Artificial Intelligence (AI) in advancing our mission to increase and diffuse knowledge. AI offers unprecedented opportunities to enhance our research capabilities, streamline operations, and create dynamic, personalized experiences for the public. However, with these opportunities come significant responsibilities. To ensure that we harness the power of AI responsibly and ethically, we have developed a comprehensive AI policy that outlines the principles and guidelines governing AI use at the Smithsonian.

1.2 Objective

The Smithsonian's AI Handbook serves as an essential companion to our AI policy, providing detailed information and best practices to support its implementation. This Handbook is designed to guide Smithsonian employees and Affiliated Persons in the secure and ethical use of AI technologies across various contexts, including business applications, scientific research, and humanities projects. By adhering to the guidelines set forth in this Handbook, we aim to foster a culture of innovation and excellence while safeguarding our Institution and community from potential risks.

1.3 Scope

The Interim AI Policy and supporting Handbook apply to all Smithsonian employees and Affiliated Persons, as defined in Section IV of the Interim AI Policy, who are engaging with AI in the course of their work for the Smithsonian, or using Smithsonian resources, such as Smithsonian devices, applications, and networks.

1.4 Related Policy and Procedures

[Interim AI Policy](#)

2. AI REVIEW COMMITTEE (AIRC)

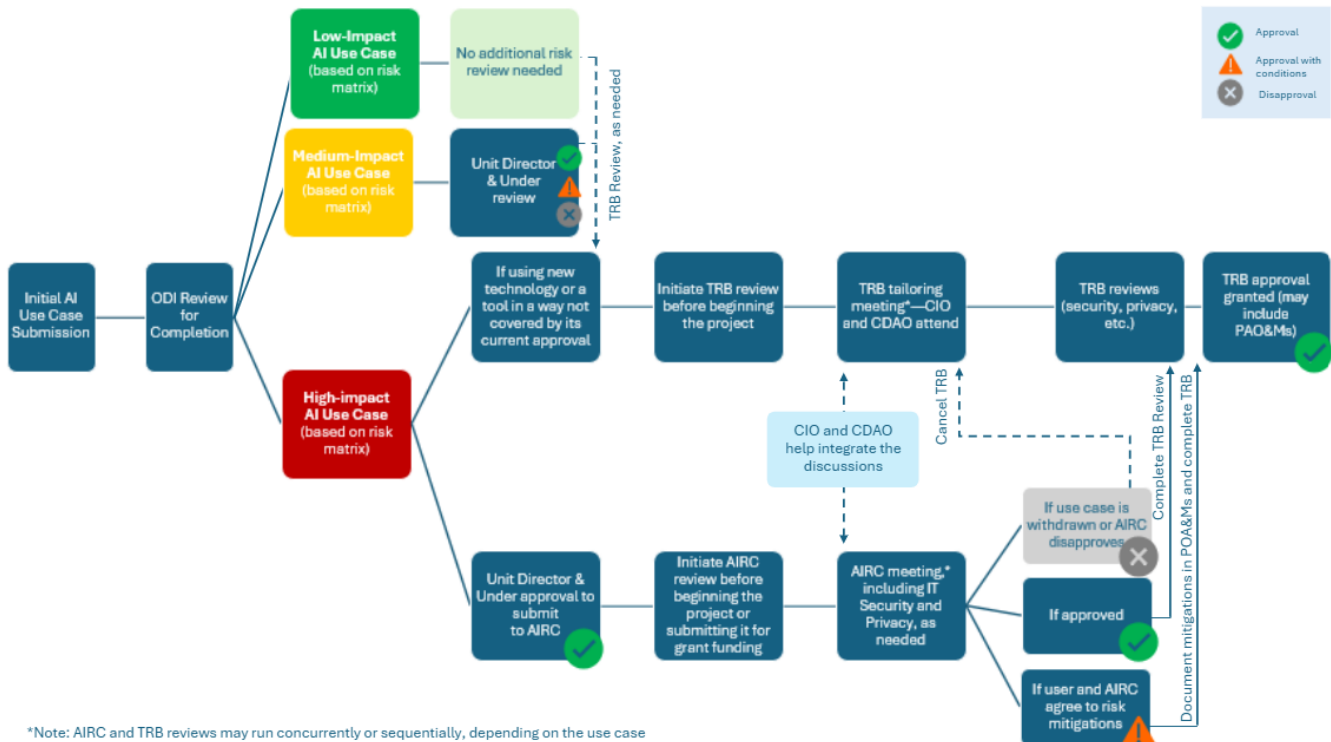
2.1 AIRC and Technical Review Board (TRB) Process Map

The AIRC works in tandem with the TRB to review high-impact AI use cases (as determined by Section 3 of this Handbook).

The AIRC is the SI leadership group that assesses high-impact use cases for institutional risk. The AI Review Committee will evaluate these AI use cases to ensure they align with the Institution's mission, values, and ethical standards. When appropriate, the Committee will provide guidance on use cases and identify risk mitigation measures for the responsible use of AI technologies.

The TRB is an IT governance body that seeks to improve the level of Smithsonian IT project success by providing guidance and support to SI projects as well as ensuring that project risk is reduced to an acceptable level. This is done through assessments at key project milestones, ensuring that Institution technology standards are followed and existing technology investments are leveraged.

The CIO and the CDAO, as established in the Interim AI Policy, are responsible for ensuring integration between the AIRC and TRB for high-impact AI use cases.



2.2 AIRC Links

This Service Now ticket should be used to submit a medium- or high-impact AI use case for review. This form and associated workflow will be used to capture approval or disapproval of the use case by your Unit Director, Under Secretary, and the AI Review Committee, when needed. For any questions on the process, please contact ODI at ai@si.edu. [Click here to create a Service Now ticket.](#)

3. AI USE CASE RISK MATRIX

3.1 Decision Table for AI Institutional Risk Review

This table clarifies which use cases require higher level review of institutional risks. Smithsonian Directives and policies, including the Interim AI Policy, must be followed for all use cases regardless of whether review is required. AI Review Committee consideration does not supplant TRB review.

If you answer “yes” to any questions in a category, your use case falls into that category. You must follow the review instructions of the highest-level risk category in which you fall. For instance, if you answer “yes” to questions in both the yellow and green columns, follow the review instructions for the yellow column. If you answer “no” to all questions, you are in the green category. To send a use case to the AIRC, first obtain Unit Director sponsorship and Under Secretary concurrence using this form: [Submit an AI Use Case](#).

AI Review Committee Review Required (High-Impact Use Cases)	Unit Director Review and Under Secretary Concurrence Required; TRB, as Appropriate (Medium-Impact Use Cases)	No Risk Review Needed; TRB, as Appropriate (Low-Impact Use Cases)
The project will involve obtaining information and/or inputs from minors or is targeting minors as end users.	The project involves the input of Non-public SI Data and it is NOT utilizing an Enterprise tool.	You are using an Enterprise tool in a manner consistent with all SI policies.
The project uses PII and/or export-controlled information as an input. This applies unless you are using an Enterprise tool in a manner consistent with all SI policies.	The outputs of the model will be prescriptive . In other words, the model outputs will recommend a specific course of action rather than provide data from which a third party will make determinations.	The data you are using is publicly available and your use is consistent with all SI policies.
The use of the model will be rights impacting . For example, decisions will be made because of the model that will impact safety, access to facilities, and/or the livelihood or wellbeing of others.	The model will be used to determine the expenditure of funds .	The output will be used solely for internal SI purposes and not circulated externally.
The project has a moderate likelihood of creating reputational risk for SI and the	The project has a moderate likelihood of creating reputational risk for SI and the	The project has a low likelihood of creating reputational risk for SI and the

reputational damage generated would be severe. OR The project has a high likelihood of creating reputational risk for SI and the reputational damage generated would be moderate or severe.	reputational damage generated would be moderate.	reputational damage generated would be mild.
--	---	---

The AIRC will also consider the environmental risk generated by pursuing a high-impact use case (i.e., environmental impact of the energy needed to support the compute requirements).

3.2 Questions for Unit Director Consideration

For use cases reviewed at the Unit level, with concurrence from the Under Secretary, Unit leadership should consider the following questions when determining whether a use case is appropriate and what mitigation may need to be enacted to balance potential risk. No one factor is determinative, and a totality of the factors should be considered.

Unit leadership can always elevate a medium-impact use case to the AI Review Committee if they think additional consideration is warranted or if they have any questions:

- Is the use case consistent with Smithsonian Directives?
- If the use case is successful, what value will be provided and to whom?
- If the use case is disapproved, what lessons learned/pathfinding opportunities would we forgo?
- Will the use case/AI-generated outputs be public facing?
- To what degree will the use case/AI-generated outputs be subject to human review prior to use?
- What other review processes are in place for this use case (TRB, IRB, OCON, peer review, etc.)?
- What is the size/scope of the inputs and outputs of the process?
- What is the environmental risk generated by pursuing this use case? (i.e., environmental impact of the energy needed to support the compute requirements)
- What is the proposed test and evaluation approach and the quantitative system performance metrics?
- What is the likelihood and severity of the following risks if the use case is approved:
 - negative social or societal impact,
 - potential reputational risk for the Smithsonian Institution,
 - bias or inaccuracy in the outputs,
 - risk of exposing non-public data.

3.3 Sample Use Case Categorization Guide

To assist users in determining where their use case falls on the decision table, here are some sample use case categories:

AI Review Committee Review Required (High-Impact Use Cases)	Unit Director Review and Under Secretary Concurrence Required and TRB, as Appropriate (Medium-Impact Use Cases)	No Risk Review Needed; TRB, as Appropriate (Low-Impact Use Case)
Creating publicly facing content tags about a culturally sensitive collection, with human moderation of results, consistent with SI policies	Create public-facing content (e.g., summaries, images) with human moderation of results, consistent with SI policies, and assuming content is not sensitive and does not contain PII.	Conducting high-level background research into a nonsensitive topic that does not include input of any non-public SI data.
Analyzing data and creating policy suggestions that will be provided directly to external Users.	Generating content tags for interpretive materials to be used on a public-facing website.	Summarizing long or technical documents for individual internal Smithsonian use.
Generating transcripts of oral history interviews, which contain PII.	Using embargoed Smithsonian research data in a non-Enterprise AI tool to analyze patterns.	Using a computer vision model on public collections to classify specimens.
Automation of any systems or equipment that may compromise life safety or the protection of property, including works of art.	Using an Enterprise AI tool in accordance with SI policies to summarize documents related to use of funds for internal SI use (e.g., pool fund applications).	Using Copilot to create a draft email invitation to a workshop for Smithsonian employees.

4. TEST AND EVALUATION GUIDELINES

This section of the Handbook provides guidelines for testing and evaluating AI models across different use cases. The protocols are designed to be proportional to the complexity and customization of the AI system being deployed.

The purpose of the guidelines is to:

- Examine the functionality, safety, and performance of the AI model
- Provide a framework for comparison with alternatives
- Establish documentation of testing procedures and results
- Enable informed decision making by users, developers, and stakeholders

These recommendations are balanced around basic principles of risk, relevance, and transparency to align with the Smithsonian vision for innovative and responsible use of AI.

4.1 Tiered Testing Framework

We recommend a tiered approach to testing based on the type of AI model and its intended use. The table below outlines 3 tiers with increasing depth of testing and evaluation required. Users of AI technology at the Smithsonian will more frequently encounter use cases that fall under Tier 1. Use cases in Tier 2 and Tier 3 should upload their Test and Evaluation plan to the SI model catalog.

Tier	Description	Examples	Testing Depth
Tier 1	AI tools with limited customization	Document summarization and drafting leveraging standard chatbots	Expedited protocol
Tier 2	Large-scale models with Smithsonian data	Using a commercial LLM to extract structured metadata from unstructured text	Enhanced protocol
Tier 3	Bespoke models built for innovative applications	Custom-trained machine learning models analyzing Smithsonian collections to uncover new scholarly insights	Comprehensive protocol

4.2 Tier 1 - AI with Limited Customization: Expedited Protocol

The most common uses of AI at Smithsonian are likely to be interactions with general-purpose AI tools and services, such as those offered by Microsoft 365 Copilot Chat, Google Workspace AI features, or similar enterprise AI platforms.

Purpose

For commercial AI tools with minimal customization used for non-critical institutional functions.

Key Testing Components

Functionality	Verify that the AI tool can perform its basic advertised capabilities within your institutional context, such as generating relevant content or responding to queries as expected.
Performance	Evaluate how well the AI performs specific tasks relevant to your use. Users can do this by testing it with representative examples and gauging output quality and consistency. Users should ensure the performance meets their practical needs.
Data verification	Users must critically evaluate the factual accuracy and reliability of information produced by AI models, including cross-checking outputs against trusted sources and identifying any inaccuracies or fabrications.

Quick Evaluation Checklist

- ☐ Core functionality meets requirements
- ☐ Performance is adequate for intended use
- ☐ Data generated by AI models undergoes human review for veracity and reliability

While Functionality and Performance only need to be tested and evaluated once per application (for the User to understand the AI Model's functions), Data Verification is required for all outputs that are used in any official Smithsonian capacity.

4.3 Tier 2 - Large-Scale Use with Smithsonian Data: Enhanced Protocol

The Enhanced Protocol applies to AI systems that interact with or are trained on substantial amounts of institutional data, including unit-specific analytical tools, specialized assistants, and customized enterprise AI models. This type of use case is likely to involve applying a pretrained AI model to perform iterative tasks on a batch of data.

Purpose

For commercial AI models that will be used with institution-specific data or for batch processing of institutional data.

Examples

- Applying an OCR (Optical Character Recognition) model to digitize a collection of scanned historical documents
- Using a commercial LLM API endpoint to extract structured metadata from unstructured text
- Implementing an image classification model to categorize visual assets in the institution's digital collections
- Deploying a speech-to-text model to transcribe recordings or interviews
- Implementing entity recognition to identify people, places, and organizations in archival data

Key Testing Components

Functionality Verification

Functionality verification for Tier 2 focuses on ensuring the AI system can perform its intended functions with institutional data at scale. This includes testing core capabilities and performance.

1. Test core functions relevant to institutional needs:
 - 1.1. Content processing capabilities (OCR, information extraction, classification)

- 1.2. Integration with data processing workflows
- 1.3. Batch processing functionality

Performance Assessment

Performance assessment at this tier requires the creation of validated ground truth data and domain-specific metrics to evaluate how well the AI system handles institutional content. Subject matter experts should be involved to ensure evaluation reflects actual use requirements.

1. Create human-annotated validation datasets:
 - 1.1. Strategically select diverse examples representing content
 - 1.2. Include edge cases and potential problem areas
 - 1.3. Ensure representation of all relevant content types
2. Develop domain-specific evaluation metrics:
 - 2.1. Work with subject matter experts to define relevant success criteria
 - 2.2. Create metrics that capture real-world impact of errors
 - 2.3. Identify critical performance factors for context
3. Test with comprehensive validation framework:
 - 3.1. Process validation datasets through AI system
 - 3.2. Measure performance against human annotations
 - 3.3. Analyze error patterns and correlations with content types
 - 3.4. Document performance characteristics and limitations

Standardized Benchmark Evaluation

Establishing standardized benchmarks allows for objective comparison between different AI solutions or versions. This is essential for making informed decisions about which tools best meet institutional needs and for tracking performance improvements over time.

1. Establish consistent testing methodology:
 - 1.1 Define reproducible testing procedures
 - 1.2 Set statistical significance thresholds
 - 1.3 Create objective scoring criteria
2. Implement comparative evaluation processes:
 - 2.1 Test multiple solutions or versions using identical datasets
 - 2.2 Quantify performance differences between options
 - 2.3 Track performance changes across updates
 - 2.4 Document trade-offs between different approaches

As AI technologies evolve rapidly with frequent model updates and new releases, maintaining this consistent evaluation framework allows you to quantitatively measure performance improvements between versions and competing tools using identical metrics.

Documentation and Limitations

Comprehensive documentation is critical for Tier 2 evaluations, as it provides the foundation for decision-making and establishes benchmarks for future comparisons. This documentation should capture both technical performance and institutional considerations.

1. Complete comprehensive evaluation documentation:
 - 1.1. Detailed testing methodology and metrics
 - 1.2. Validation dataset characteristics
 - 1.3. Performance benchmarks and comparative results
 - 1.4. Error analysis and identified limitations
2. Document testing scenarios and results
3. Provide recommendations for further testing

4. Identify any institutional-specific limitations or concerns

Document your evaluation methodology thoroughly, including scoring criteria and statistical significance thresholds, to ensure results remain actionable for comparison with alternatives over time.

Enhanced Evaluation Checklist

- ☐ Core functionality meets requirements
- ☐ Human-annotated validation datasets created and documented
- ☐ Domain-specific evaluation metrics developed with experts
- ☐ Performance testing completed with statistical analysis
- ☐ Error patterns analyzed and documented
- ☐ Comparative evaluation conducted (if multiple options available)
- ☐ Comprehensive documentation

4.4 Tier 3 - Bespoke AI Models: Comprehensive Protocol

The Comprehensive Protocol applies to custom-developed or significantly fine-tuned AI models designed for specific applications, innovative research applications, or public-facing services. These bespoke models may be trained or extensively customized using institutional data and expertise to address specialized needs that cannot be adequately met by off-the-shelf solutions.

Purpose

For custom-built AI models or highly customized systems used for critical institutional functions, innovative research, specialized scholarly applications, or significant public engagement initiatives.

Examples

- Custom-trained machine learning models analyzing Smithsonian collections to uncover new scholarly insights
- Specialized NLP models fine-tuned on discipline-specific terminology for research applications
- Bespoke computer vision systems developed to identify unique characteristics large image datasets
- Custom recommendation systems designed specifically for institutional digital platforms
- Specialized knowledge retrieval systems built on institutional archives and expertise

Key Testing Components

Functionality Testing

Bespoke AI models require extensive functionality testing to ensure they meet the specialized requirements that prompted their development. This testing should verify that the model performs as designed across all intended use cases and within all operational requirements.

1. Validate model against specialized requirements:
 - 1.1. Test alignment with specific research methodologies and scholarly approaches
 - 1.2. Verify functionality for specialized use cases
 - 1.3. Assess innovative capabilities and novel applications
2. Test integration with institutional infrastructure:
 - 2.1. Specialized institutional databases and systems
 - 2.2. Custom APIs and data pipelines
 - 2.3. Research and collection management infrastructure
3. Conduct testing with complex institutional scenarios:
 - 3.1. Performance with multidisciplinary applications

- 3.2. Handling of unique institutional data characteristics
- 3.3. Response to edge cases specific to institutional context

Performance Assessment

Performance evaluation for bespoke models must be rigorous, as there are often no direct comparisons available. This requires creating custom evaluation frameworks that assess performance against the specific needs the model was designed to address.

1. Establish performance baselines:
 - 1.1. Define domain-specific success metrics relevant to the application
 - 1.2. Develop specialized test datasets
 - 1.3. Create benchmarks relevant to the model's intended purpose
2. Conduct in-depth performance analysis:
 - 2.1. Evaluate performance across all intended applications
 - 2.2. Test robustness under varying conditions
3. Assess long-term performance sustainability:
 - 3.1. Performance stability with evolving data
 - 3.2. Degradation testing under challenging conditions
 - 3.3. Maintenance requirements and update protocols

Data Verification

Custom models trained on specialized data require verification to ensure accuracy, reliability, and appropriate representation of the training data. This is especially critical for models that will be used in research or public-facing applications.

1. Implement comprehensive verification system:
 - 1.1. Multi-layered fact-checking against authoritative institutional sources
 - 1.2. Expert review by relevant subject matter specialists
 - 1.3. Verification of model outputs against established knowledge
2. Test for knowledge boundaries and limitations:
 - 2.1. Systematic identification of knowledge gaps
 - 2.2. Documentation of model behavior with novel or ambiguous inputs
 - 2.3. Assessment of confidence metrics and uncertainty quantification
3. Develop knowledge verification protocols:
 - 3.1. Establish ongoing verification processes for model outputs
 - 3.2. Create feedback mechanisms for expert correction
 - 3.3. Document verification standards for different application contexts

Advanced Safety and Ethical Assessment

Bespoke models representing institutional knowledge or serving important functions require thorough safety and ethical evaluation to ensure they reflect institutional values and handle sensitive materials appropriately.

1. Conduct comprehensive risk assessment and perform ethical review aligned with institutional values. This should be done in line with SI's AI Use Case Risk Matrix (Handbook Section 3):
 - 1.1. Detailed analysis of potential misuse scenarios
 - 1.2. Assessment of unintended consequences for institutional reputation
 - 1.3. Alignment with institutional mission and ethical frameworks
 - 1.4. Review of fairness and inclusivity in institutional context
 - 1.5. Assessment of transparency and accountability mechanisms
2. Test specialized safety safeguards:
 - 2.1. Adversarial testing specific to the model's domain

- 2.2. Evaluation of robustness against potential manipulation
- 2.3. Testing of safeguards for sensitive content

Comprehensive Documentation and Governance

Bespoke AI models require extensive documentation and governance frameworks to ensure responsible development, deployment, and maintenance throughout their lifecycle.

1. Create detailed model documentation:
 - 1.1. Complete technical specifications and architecture details
 - 1.2. Training methodology and data usage documentation
 - 1.3. Performance characteristics and known limitations
2. Develop governance framework:
 - 2.1. Oversight structure appropriate to the model's function and impact
 - 2.2. Monitoring protocols specific to the intended applications
 - 2.3. Assign responsible and accountable parties
3. Prepare implementation and sustainability plan:
 - 3.1. Long-term maintenance and evolution roadmap
 - 3.2. Knowledge transfer and institutional capacity building

Comprehensive Evaluation Checklist

- ☐ Complete requirements validation with institutional stakeholders, potentially including Unit and central risk reviews per Handbook Section 3
- ☐ Comprehensive functionality testing across all intended applications
- ☐ Custom performance evaluation framework established, implemented, and documented in AI's model catalog
- ☐ Thorough data verification completed with subject matter experts
- ☐ Advanced safety and ethical assessment documented in AI's model catalog
- ☐ Complete technical documentation prepared
- ☐ Governance framework established
- ☐ Implementation and sustainability plan developed
- ☐ Knowledge transfer protocols established

4.5 Conclusion

AI capabilities, methodologies, and best practices are advancing rapidly, requiring continuous reassessment of evaluation standards. Similarly, Smithsonian use cases will evolve as AI becomes more deeply integrated into research, operations, and public engagement activities. What constitutes appropriate testing for a particular application today may change as expectations, risks, and opportunities shift. We recommend that users approach this framework as a baseline rather than a rigid prescription.

Regular review of the testing protocols should be conducted to ensure they continue to serve the institution's commitment to excellence, innovation, and transparency in the application of AI.

5. APPROVED AI TOOLS AND MODELS

As AI tools and models are reviewed and approved, they will be posted to the OCIO AI Tech Store. Service Now will have this, and other AI guidance, available to all SI account holders. If a User would like to leverage an Enterprise AI tool for a Smithsonian purpose but does not already have access to the tool, the User may request access from the CIO by describing the business use-case in an email submitted to SAPATRB@si.edu. Business-use proposals must include the User's supervisor approval. The CIO will prioritize review of business-use proposals based on determination of the availability and best use for Smithsonian financial and technical resources.

The information for Enterprise AI Tools can be found here:

[Enterprise Artificial Intelligence \(AI\) Tools](#)

6. MODEL CATALOGING GUIDELINES

Users leveraging and developing AI Models should document to the best of their ability and with all available information, the following information in SI's central model catalog. ODI is working to procure a robust model cataloging tool. At present, model information and documentation should be stored in the [interim catalog](#).

6.1 AI Model Documentation Components

1. Model Information
 - 1.1. Model Name: The unique identifier or name of the AI model
 - 1.2. Version: The version number to track updates and changes
 - 1.3. Description: A brief overview of the model's purpose and functionality
 - 1.4. Type: Classification of the model (e.g., LLM, vision model, multimodal, etc.)
 - 1.5. Release Date: When this version was released
 - 1.6. Developer/Owner: Individual or team responsible for the model
2. Intended Uses and Limitations
 - 2.1. Primary Intended Uses: Specific use cases the model was designed for
 - 2.2. Out-of-Scope Uses: Use cases explicitly NOT recommended
 - 2.3. Known Limitations: Key limitations users should be aware of
 - 2.4. Institutional Context: How this model aligns with institutional needs
3. Technical Specifications
 - 3.1. Algorithm: The type of algorithm used (e.g., neural network, decision tree)
 - 3.2. Architecture: Details about the model's architecture
 - 3.3. Model Size: Number of parameters, model weights size
 - 3.4. Input Requirements: Expected input formats and constraints
 - 3.5. Output Format: Description of model outputs and formats
 - 3.6. Hardware Requirements: Computing resources needed
4. Training Information
 - 4.1. Training Data: Sources, composition, and preprocessing steps
 - 4.2. Training Dataset Size: Number of examples/records
 - 4.3. Data Preprocessing: Steps taken to prepare training data
 - 4.4. Training Procedure: Methodology, hyperparameters, and approach
 - 4.5. Training Infrastructure: Computing resources used

5. Performance Metrics
 - 5.1. Accuracy: The model's overall accuracy on test data
 - 5.2. Precision and Recall: Metrics for classification tasks
 - 5.3. Confusion Matrix: Detailed breakdown of predictions
 - 5.4. Benchmark Comparisons: Performance against standard benchmarks
6. Bias and Fairness Assessment
 - 6.1. Bias Impact: Performance variation across classes in the model
 - 6.2. Bias Mitigations: Steps taken to address identified biases
 - 6.3. Remaining Concerns: Acknowledged limitations in bias mitigation
 - 6.4. Protected Attributes: How the model handles sensitive characteristics
7. Operational Details
 - 7.1. Deployment Environment: Where the model is deployed (e.g., cloud, on-premises)
 - 7.2. Dependencies: Software or hardware dependencies required
 - 7.3. Resource Requirements: Compute, memory, and storage needs
 - 7.4. Integration Points: How the model connects to other systems
 - 7.5. Monitoring Framework: How the model is monitored in production
8. Governance and Compliance
 - 8.1. Ethical Considerations: Documentation of ethical implications and mitigations
 - 8.2. Risk Assessment: Evaluation of potential risks with the model's use
 - 8.3. User Access Controls: Authorization framework for model access
 - 8.4. Governance Framework: Oversight mechanisms and responsible parties
9. Licenses and Attribution
 - 9.1. Model License: License governing model use
 - 9.2. Dataset License(s): Licenses covering training data
 - 9.3. Required Citations: Citations for proper attribution
 - 9.4. Intellectual Property Status: IP ownership and restrictions
 - 9.5. Third-Party Components: Any licensed components incorporated
10. User Resources
 - 10.1. User Guide: Instructions on how to use the model
 - 10.2. Example Implementations: Sample code or implementation patterns
 - 10.3. Known Issues: Currently identified issues or bugs
 - 10.4. FAQs: Frequently asked questions and answers
 - 10.5. Support Contacts: Where to get help with this model
11. Maintenance and Updates
 - 11.1. Maintenance Plan: How the model will be maintained
 - 11.2. Responsible Parties: Who maintains the model
 - 11.3. Update Frequency: Expected cadence of updates
 - 11.4. Retraining Criteria: Conditions that would trigger retraining
 - 11.5. Version History: Log of changes between versions
12. Reproducibility Information
 - 12.1. Code Repository: Links to relevant code repositories
 - 12.2. Reproduction Steps: Instructions to reproduce training/evaluation
 - 12.3. Seeds and Constants: Random seeds and fixed parameters
 - 12.4. Validation Approach: How results were validated
 - 12.5. Institutional Review: Details of any internal review process completed

7. AI Security Requirements

AI systems process data and produce outputs in fundamentally different ways than traditional software, creating unique security challenges. This section provides security guidance for using both existing AI tools and developing new ones.

Note: This section complements the Testing and Evaluation Guidelines (Section 4). While Section 4 covers functionality and performance testing, this section focuses on security controls and threat mitigation.

7.1 GenAI

GenAI tools pose specific risks because of how they learn and share information.

- Any text that is put into these tools can be used to train future versions of their language models. This means that if you put non-public information about Smithsonian collections, staff information or any PII, that data could become the answer to future searches by anyone using them, effectively making the data public. As such, it is important to have contractual language in place to control the use of information submitted to any GenAI tools used with SI data.
- As new specialized tools using generative AI are being made available, validate that they are from a trusted source before using them. The best method of validation is through the TRB.
- Do not attempt to install any AI app on a device until OCIO approves them.
- Do not create accounts on AI platforms using your Smithsonian network ID or current SI password(s).

7.2 GenAI-created Code

GenAI can accelerate coding, but this code can introduce significant security risks. Code review is critical.

- Code or software libraries generated by GenAI on Smithsonian systems must be thoroughly reviewed and understood by developers before the code is committed.
- Any code Libraries, and references to external/3rd party code libraries, that are added/created by GenAI tools, must be validated before the library is used. Developers must not even run code tests until they have validated that the library a) exists, b) is actively run and managed, and c) not run and managed out of a country of concern as defined by the department of state or CISA's list of Nation-State cyber actors.
- Code or software libraries generated by GenAI on Smithsonian systems must not be used in critical systems, or systems that contain sensitive data such as SPII, PCI, or security data. This is because any prompt, or code generated is assumed to become part of the source model.
- If SI has a contract with a GenAI code tool that keeps prompts, produced code, and any user feedback out of the model and/or long-term session history, then that tool would be exempted from the above requirement.

- Some developer tools have AI components for reviewing/fixing code. These should only be used with TRB review and approval, and appropriate contracts in place.

7.3 System Owner and Manager Responsibilities

The System owner and system manager are key roles for any IT system, but particularly for AI systems given the need to actively monitor a rapidly changing industry. By default, the owner is the manager as well, though those responsibilities can be delegated to another SI staff member. In either case, there should always be at least one additional individual with both knowledge and responsibility to manager AI systems, so that someone may take action if the first is out of the office or leaves their role.

1. They are responsible for validating new use cases and features with the TRB/IT security.
 - a. New use cases, not considered during the original review, may require an IT security review if deemed necessary by the IT security TRB approver.
2. High-impact use cases, particularly those that potentially impact the safety and/or rights of individuals, must be reviewed by the TRB/IT security before they are implemented.
3. Non-tools that incorporate/embed and AI function into their solution will require re-review of that tools new AI capabilities and security, unless that AI functionality is disabled in the administrative settings.
4. New features of Enterprise AI tools may require additional TRB/ IT security review if deemed necessary by the IT security/ TRB approver, when the new features add use cases to an approved software package that have different review requirements than those the solution was approved for.
5. When selecting AI tools, Preference should be given to tools/data models that provide information about how the AI component produced its outputs, providing transparency and explainability for review by SI staff.

7.4 Data

AI Tools and Models are only as good as the data used to train, tailor, and/or run them. Access by malicious actors can negatively impact the outputs of AI models. To this end, it is imperative that System Owners/developers know, in detail, what data they will be using, how it is stored, and where it is transmitted as it moves through both the business processes and AI model(s). The following are a

1. Because so much of AI products behavior is derived from the underlying data, system managers must review changes to the tools/models/software when the data used to train the AI model changes.
2. Initial tailoring, using SI data to focus/refine an existing data model, must be reviewed in detail before any SI data is exposed to the AI model or AI tool.
 - a. Further tailoring, after the initial training and SI customization using data is exempt from review, provided the data elements are not changed.
3. Whenever possible, sensitive data (PII, SPII, etc.) should be sanitized, anonymized, or tokenized prior to incorporation into AI models.
 - a. Use of unmodified sensitive data requires approval from the Privacy Officer.
4. AI projects must document their process to account for bias. Output may also incorporate the biases of the data sets used to train the tools, which could lead to systemic errors or the favoritism of certain groups or beliefs, resulting in biased and discriminatory outcomes. Relying on false, biased, or copyrighted information is not consistent with the Smithsonian's

mission and values of respect, fairness, and integrity and Our Shared Future to be a Trusted Source and our commitment to diversity, equity and inclusion.

7.5 AI Model Protection

AI models are run on complex infrastructure, and can have many layers of activity, and often multiple models working in partnership to produce their outputs. Protecting these systems is critical for securely running an AI tool, model, or system.

1. All AI models/tools implemented at the Smithsonian should have an account management plan defining access to both any administrative portion of the system, and the user access.
 - a. This plan should include specific system roles, and any criteria for granting access to those roles.
 - b. It should include any approval processes required for access-.
 - c. It should include any account/access monitoring that will be done.
 - d. It should define authentication requirements and methods, including if the system will use SI SSO.
 - e. If the system provides any access directly to a model or data the model will train/tailor/run against, the access to these components must be clearly and strictly defined for system roles, and access to those roles restricted only to those who need them.
2. Augmentation and runtime data
 - a. Some modern AI models/methods are designed to run against data repositories to improve their responses. These data repositories will be treated as sensitive, regardless of their content, as changes to them can influence the AI behavior.

7.6 Unique AI Vulnerabilities

AI systems face attacks that don't exist in traditional software. System owners and managers are expected to understand these vulnerabilities and work with IT staff to mitigate their risks.

Attack Type	Description	How It Works	Impact	Prevention
Data Poisoning	Attackers inject bad data during training phase	Adding mislabeled or malicious data to training datasets	AI produces attacker-preferred outputs; compromised decision-making	Strict access controls and data validation during training
Model Extraction	Repeated queries to reconstruct private training data	Analyzing patterns across many slightly different queries over time; may use short bursts spread out to avoid detection	Exposure of confidential SI data used in training; recreation of proprietary models	Monitor for rapid, systematic query patterns and unusual query velocities
Adversarial Inputs	Specially crafted inputs designed to fool AI systems	Creating inputs with subtle modifications invisible to humans but causing AI errors	Bypassing security controls; generating harmful outputs; manipulating AI recommendations	Input validation, robust guardrails, and continuous model monitoring
Prompt Injection	Embedding hidden commands in seemingly innocent prompts	Carefully structured inputs that bypass AI safety controls	AI ignores safety rules; unauthorized access to information/data	Input sanitization, regularly updated controls, and strong guardrails
API Attacks	Bypassing user interfaces to directly access AI APIs	Attacking APIs to bypass GUI controls; exploiting poorly designed systems for internal access	Access to internal functions and data repositories; unauthorized system control	API authentication, usage monitoring, and detection of API spikes
Model Replication	Attempts to copy the entire AI model	Similar to model extraction but aims to replicate the complete model for unauthorized use	Intellectual property theft; unauthorized use of SI models	Same as model extraction: query pattern monitoring
AI Backdoor	Hidden commands embedded through data poisoning	Creating trigger words or patterns that cause specific misclassifications	Normal operation most of the time, but controlled misbehavior when triggered	Data quality control during training; difficult to detect in operation
Data Inference	Deriving information not directly in the model	Using model outputs combined with external data sources to infer protected information	Exposure of data relationships and patterns not intended for release	Monitor for broad query patterns; limit output specificity

7.7 AI Model Development

When creating an AI model, or a tool that uses AI (whether and LLM or other AI methods), there are additional considerations that must be taken into account due to the difference in the way such tools

are built, implemented, and maintained. This also includes projects that take existing AI models/tools, and use SI data to tailor, augment retrieval, or otherwise provide access to those models/tools. For the purpose of this Handbook, any of the above activity will be referred to as AI Development.

The following requirements should be reviewed and designed into any Smithsonian AI projects. This includes projects run by staff, contractors, or other 3rd parties when developing the AI product on behalf of the Smithsonian, with Smithsonian resources, or using non-public Smithsonian data based on the criteria set forth in the Interim AI Policy. This explicitly does not apply to researchers using AI based methods as part of their research and/or publication processes. If research work falls into one of the three criteria from the Interim AI Policy, they should check with IT Security and/or Privacy about their intended use of AI.

Not all of the below information has to be known in detail at the start of the project, but the project team should be prepared to address all elements/concerns in detail before related milestones.

Development requirements

1. AI development that intends to train/tailor an AI model using SI data must have a minimum of 3 separate environments defined below.
 - a. Dev – The Dev environment is to be used to stand up and test infrastructure, and any non-model code with test/dummy data. This includes the creation of an external API calls, or inbound data connections.
 - b. Model development/training – This environment is for the building/training/tailoring of AI models/tools with SI data. Because such work often requires large amounts of data, both in type and quantity, this environment is not permitted to have any data exfiltration, except to meet retention requirements. All external environment communication and access should be limited to data scientists/developers actively working on the model training.
 - i. A project that will use an existing AI model without tailoring/refinement may skip the model development environment.
 - c. Production – The production environment should have limited access by developers, and that access should be limited in duration and purpose to fix production issues.
 - d. Additional environments such as Test, QA, or UAT may also exist. The above environments, other than production, may also be used for the above functions, if those functions do not contradict the requirements. It is recommended, though not required, that an additional environment be used to test the combination of the trained AI model and externally facing code.
2. Many AI programs are run wholly or partially in the cloud. When AI development occurs in the cloud, OCIO cloud guidance should be followed.
3. AI Development must produce a separate Account management and access plan for the development team that defines the technical roles for the standup and development of the AI model/tool.
4. AI development must document their environments, and the methods used to progress code and infrastructure across those environments.
 - a. This should include a simple diagram showing infrastructure, code, and data model migration and deployment
 - b. This should include a reference to the account management plan and the technical role list, defining who is able to promote/migrate system elements

- i. There should be separation of duties between the developers/data scientists and the code migration functions. No single person should be able to make code/model changes and promote those changes to another environment.
- 5. Inputs/prompts must be pre-processes using up-to-date methods.
 - a. Sensitive data should be filtered out of prompts
 - b. Inputs should check for malicious activities, and alert when known attack types are detected.
 - c. Establish guardrails, rules that instruct a model on how to respond or not respond to specific topics, should be created and documented for AI development projects.
- 6. Outputs should be filtered to check for sensitive/detailed information that the project does not intend to share

Data Requirements

- 1. Developers must catalog and maintain a record of each step followed, including the algorithms and the complete data set relied upon to create and train a SI AI Model or a SI Collaborative AI Model so that the model can be recreated at a later date.
- 2. Developers must review changes to their models/software output/behavior when the data or use changes.
- 3. SI data should only be allowed in Production, the Model Training, and at most 1 other environment such as UAT or Test.
 - a. Model development/training environments must have duplicate security controls/protections to the production environment, and may have more strict controls, depending on the amount of data stored there
 - b. Any UAT or Test environment using real SI data, or the trained model must be secured with the same controls as the Production environment before any data may be moved into the system.
- 4. Data used to train/tailor models should only be allowed in the Model Development Environment.
 - a. Data may not be exfiltrated from the environment, except as part of SI retention requirements.
 - i. If it is exfiltrated from the environment, it must be encrypted in transit and deleted from the environment after exfiltration.
 - ii. Training data should be deleted from the Model training environment as soon as permitted by SI retention policy
 - b. Because any/all data used to create a model is forever part of the model, and retrievable, models are the same data sensitivity/classification as the data used to create the model.
- 5. Generate operations/maintenance testing scripts or plan to evaluate model drift after the launch of the AI Model/tool

General Development Practices

AI development projects should provide a clear purpose for the development work, and the expected behaviors/outputs of the project prior to initiating the development engagement.

AI developers must identify anticipated rates of erroneous behavior for outputs, including hallucinations, as part of the design and development effort of any SI AI Model. This information should be clearly identified for those with access to the model.

- SI developed models should provide traceability and referential material from the AI outputs to the source(s) used to create those outputs. This provides transparency and trustworthiness as part of the model/tool.

Use of 3rd party AI tools and models must be reviewed and tracked.

- AI tools will be tracked as part of Cyber Supply chain Risk management, through the OCIO IT Security Staff program.
- 3rd Party AI models used should be captured according to the Model Cataloging Guidelines and sent to the AI Review Committee.

AI models created by and for SI should not be treated as a complete upon launch of the model or product. Accuracy of data models dwindles over time, and that accuracy, as well as other information such as hallucination rate, should be monitored over time and corrected as needed.

Data models and the code surrounding them should be made available to other SI organizations with similar needs. Reuse of models and code should be reviewed with the TRB, Privacy Office, and IT Security.

- SI Data models and code should be shared with AIRC to improve the ability of other groups to see what is available.
- Critical models (i.e., those whose exposure could have a negative impact on SI work or expose sensitive data) should be tightly controlled, and shared rarely, if at all.

Development tools (IDEs) should be reviewed to make sure that developers are not inadvertently sharing model information, keys, or datasets outside of SI's networks.